École Supérieure des Communications de Tunis
SUP'COM

Cycle ingénieur – Option CySeD – Sécurité Applicative

TupleTrace

RECUEIL DES BESOINS

FONCTIONNELS ET SRE

Plateforme de partage de jeux de données
traçables par tatouage et empreinte numérique

Security Requirements Engineering (SRE)
SQUARE – Cas d'abus – CIA – Exigences vérifiables

Équipe : OMRANE Yosr, AMMAR Chaima et BEN AMOR Hayet

Encadrant : Mohamed Becha KAANICHE

Année universitaire : 2026–2027

Table des matières

1 Objet et portée du document **2**

2 Acteurs et parties prenantes **3**

3 Méthodologie d'ingénierie SRE retenue **4**

4 Besoins fonctionnels détaillés **5**

5 Actifs critiques et frontières de confiance **6**

6 Analyse des menaces et scénarios d'abus **7**

7 Évaluation et priorisation des risques **8**

8 Exigences de sécurité – identité et accès **9**

9 Exigences – données, marques et clés **10**

10 Exigences – audit, résilience et investigation **11**

11 Cas d'abus propres à TupleTrace **12**

12 Plan de vérification et tests de sécurité **13**

13 Justification de la détection statistique **14**

14 Gestion des exigences, livrables et évolution **15**

1 Objet et portée du document

1.1 But du recueil

Ce document constitue le second livrable de cadrage du projet **TupleTrace**. Il complète le *cahier des charges* en détaillant les besoins fonctionnels et, séparément, les exigences de sécurité définies avant le développement. Il doit servir de référence pour la conception, les tests et la maintenance des exigences.

1.2 Rappel du système

TupleTrace est une application SPA/PWA dont le middleware utilise Jakarta EE 11, WildFly 42 et Java 25. Elle permet de partager des fichiers tabulaires comportant des colonnes numériques, avec deux marques complémentaires :

— un **watermark de propriété**, commun aux copies du même jeu, pour étudier l'origine ;

— un **fingerprint individuel**, propre à une distribution, pour rechercher la copie correspondante.

L'investigation examine un extrait retrouvé et rend une conclusion statistique avec les limites de confiance applicables.

1.3 Périmètre SRE

L'analyse couvre les comptes, les autorisations, les données brutes, les copies marquées, les identifiants des destinataires, les secrets cryptographiques, les rapports et le registre d'audit. Elle intègre les scénarios d'abus de l'interface web, des API et des opérations de marquage et de détection.

> **Principe directeur :** la sécurité est une exigence dès la spécification (*Shift-Left*). Les besoins de sécurité sont précis, mesurables et testables, et restent distingués des besoins métier.

1.4 Conventions de traçabilité

— **F-XX** : besoin fonctionnel du cahier des charges.

— **SEC-XX** : exigence de sécurité.

— **AB-XX** : cas d'abus ; **T-XX** : scénario de test.

— Priorités : *Must* (obligatoire), *Should* (important), *Could* (extension).

2 Acteurs et parties prenantes

2.1 Acteurs métier

Acteur	Besoin et responsabilité
Propriétaire	Importer, classifier et tatouer ses jeux de données ; connaître la qualité obtenue.
Gestionnaire de distribution	Créer les copies par destinataire, gérer les autorisations et suivre les remises.
Destinataire	Télécharger uniquement la copie qui lui est destinée et dont l'accès reste valable.
Enquêteur	Importer un extrait suspect ; recevoir un résultat d'analyse et un rapport signé.
Administrateur	Exploiter la plateforme, gérer les comptes et surveiller l'état des services, sans accès métier implicite.

2.2 Parties prenantes de sécurité

Les utilisateurs légitimes cherchent la confidentialité des jeux de données et une investigation fiable. L'organisation doit pouvoir faire vérifier les actions sensibles. Les développeurs et les exploitants ont besoin d'exigences testables, d'une configuration reproductible et de procédures d'intervention documentées.

2.3 Adversaires considérés

— **Externe non authentifié :** tentative d'accès aux fichiers ou d'abus des API.

— **Destinataire abusif :** tentative de redistribution ou de suppression d'une empreinte.

— **Utilisateur interne :** tentative d'accès à une autre organisation ou de modification du registre.

— **Groupe de destinataires :** comparaison de copies pour perturber une attribution (collusion).

La collusion est étudiée comme menace, mais la résistance forte à cette attaque n'est pas promise pour le MVP.

3 Méthodologie d'ingénierie SRE retenue

3.1 Choix de SQUARE

L'approche principale est **SQUARE** (Security Quality Requirements Engineering), complétée par des **cas d'abus**. SQUARE permet de partir des actifs et des objectifs, d'évaluer les risques, puis de formuler et prioriser les exigences. Les cas d'abus obligent à considérer ce qu'un acteur malveillant essaierait exactement de faire avec les fonctionnalités de TupleTrace.

3.2 Application des neuf étapes SQUARE

Ét.	Étape SQUARE	Application à TupleTrace
1	Convenir des définitions	Définir watermark, fingerprint, clé, copie, attribution et risque.
2	Identifier actifs et objectifs	Lister données, identités, clés, registres et objectifs CIA.
3	Produire les artefacts	Cartographier les flux, les acteurs et les cas d'abus.
4	Évaluer les risques	Estimer impact, vraisemblance et risque résiduel.
5	Choisir les techniques d'élicitation	Analyser scénarios métier et attaques, revue du cahier et ateliers.
6	Recueillir les exigences	Formuler les contrôles spécifiques aux fonctions F-01 à F-20.
7	Classer les exigences	Regrouper par identité, accès, confidentialité, intégrité, audit, disponibilité.
8	Prioriser les exigences	Définir Must/Should/Could suivant les risques et le périmètre MVP.
9	Inspecter les exigences	Vérifier cohérence, testabilité, couverture et absence d'ambiguïté.

3.3 Livrables de la démarche

Le processus produit le registre des actifs, l'analyse des risques, les cas d'abus, le catalogue SEC et la matrice reliant chaque exigence à un test. Il sera révisé lors des changements de périmètre et des nouveaux thèmes du cours.

4 Besoins fonctionnels détaillés

4.1 Protection et tatouage de propriété

ID	Besoin	Priorité
F-01	Importer CSV ou table PostgreSQL et profiler les types, plages et distributions des colonnes.	Must
F-02	Choisir les colonnes marquables et fixer la tolérance maximale de distorsion par colonne.	Must
F-03	Insérer une marque de propriété dans des positions numériques à faible impact.	Must
F-04	Produire un rapport de distorsion : erreur moyenne/maximale, moyennes et variances.	Must
F-05	Versionner les jeux et conserver le SHA-256 du fichier original.	Should
F-06	Cacher éventuellement une référence de licence chiffrée dans une zone compatible.	Could

4.2 Distribution et fingerprinting

ID	Besoin	Priorité
F-07	Gérer destinataires, contrats et permissions de partage.	Must
F-08	Produire une copie portant une empreinte dérivée de la sous-clé du destinataire.	Must
F-09	Proposer des liens temporaires, limités et révocables.	Must
F-10	Tenir un registre signé : copie, destinataire, hash et horodatage.	Must
F-11	Révoquer les autorisations futures et consulter l'historique.	Should

4.3 Investigation, évaluation et fonctions transverses

ID	Besoin	Priorité
F-12	Soumettre un extrait suspect comportant éventuellement lignes ou colonnes manquantes et valeurs modifiées.	Must
F-13	Détecter la marque de propriété par une décision statistique, une p-valeur et un seuil explicites.	Must
F-14	Tester les sous-clés des destinataires avec correction des comparaisons multiples.	Must
F-15	Générer un rapport signé indiquant résultat, éléments de preuve et limites de confiance.	Must
F-16	Simuler suppression, échantillonnage, arrondi, bruit et réordonnancement.	Must
F-17	Mesurer détection, faux positifs, attribution, distorsion et performance.	Should
F-18	Authentifier, attribuer des rôles et isoler les organisations.	Must
F-19	Fournir une SPA/PWA de suivi, d'import, de distribution et d'investigation.	Must
F-20	Conserver des événements d'audit chaînés et contrôler leur intégrité.	Must

5 Actifs critiques et frontières de confiance

5.1 Inventaire des actifs

ID	Actif	Conséquence d'une compromission	CIA
A1	Originaux CSV et tables	Divulgation, modification des données de référence	C,I
A2	Copies marquées	Fuite, substitution ou distribution non autorisée	C,I
A3	Clés de tatouage et de dérivation	Falsification d'empreintes et attribution trompeuse	C,I
A4	Registre de distribution	Attribution faussée ou historiques perdus	I,D
A5	Comptes, rôles et sessions	Usurpation d'identité et escalade des droits	C,I
A6	Rapports et traces d'audit	Dissimulation d'événements ou falsification de preuve	I,D
A7	Service de traitement	Indisponibilité, épuisement des ressources	D

5.2 Flux et frontières de confiance

1. **Navigateur → API :** flux non fiables ; identité, permissions et saisies à vérifier côté serveur.
2. **API → moteur métier :** seules les opérations validées peuvent déclencher un marquage ou une enquête.
3. **Moteur → stockage :** originaux, copies et fichiers temporaires en espace privé.
4. **API → PostgreSQL :** données filtrées par organisation, accès paramétrés.
5. **Service → secrets :** accès contrôlé aux clés sans exposition au frontend ni au dépôt.

5.3 Hypothèses

Les opérations sont menées sur des données publiques ou synthétiques pour l'atelier. Les identifiants stables des lignes sont nécessaires à une sélection déterministe ; si ces identifiants disparaissent d'un extrait, la détection peut devenir impossible. La résistance à toutes les transformations n'est pas garantie.

6 Analyse des menaces et scénarios d'abus

6.1 Menaces spécifiques

Menace	Scénario
M-01	Un utilisateur manipule une référence de copie et tente d'accéder aux données d'une autre organisation.
M-02	Un acteur dépose un CSV volontairement excessif ou invalide pour monopoliser la mémoire et le CPU.
M-03	Un destinataire modifie/arrondit les valeurs pour perturber la détection de sa copie.
M-04	Un initié tente de remplacer un rapport ou de modifier la correspondance copie–destinataire.
M-05	Un attaquant tente d'introduire une fausse empreinte ou une fausse conclusion statistique.
M-06	Un acteur cherche à obtenir les secrets de marquage pour produire de fausses copies.
M-07	Plusieurs destinataires comparent leurs copies pour affaiblir l'identification.

6.2 Lecture CIA de ces scénarios

— **Confidentialité :** M-01, M-06 et divulgation des données dans les journaux.

— **Intégrité :** M-03, M-04, M-05, M-07 et falsification des rapports.

— **Disponibilité :** M-02 et surcharge des traitements de marquage/détection.

6.3 Principe de réponse

Chaque menace donne lieu à un contrôle vérifiable. Lorsqu'une attribution n'est pas fiable, l'application doit afficher *indéterminé* et documenter les limites ; elle ne doit pas désigner artificiellement un destinataire.

7 Évaluation et priorisation des risques

7.1 Méthode qualitative

Pour un premier classement, on retient deux notes de 1 à 3 : *vraisemblance* V et *impact* I. Le score est $R = V \times I$. Il s'agit d'une estimation de conception, à réviser après les tests.

ID	Risque	V	I	R	Décision
R-01	Accès inter-organisations	2	3	6	Must : autorisation par objet
R-02	Divulgation des clés	2	3	6	Must : gestion centralisée des secrets
R-03	Attribution erronée	2	3	6	Must : test et seuil statistique
R-04	Saturation par fichiers	3	2	6	Must : quotas et traitements bornés
R-05	Altération du registre	2	3	6	Must : signature et contrôle d'intégrité
R-06	Collusion de copies	2	2	4	Analyser ; extension robuste hors MVP

7.2 Critères de priorité

— **Must :** empêcher une violation majeure CIA ou une conclusion fausse non signalée.

— **Should :** améliorer la résilience, la couverture ou la démonstration des preuves.

— **Could :** raffinement technique sans compromettre le scénario de base.

Une menace retenue doit pouvoir être reliée à une exigence **SEC-XX**, à un test et à un statut de validation.

8 Exigences de sécurité – identité et accès

Les exigences ci-dessous sont normatives pour le périmètre retenu. Les critères de test décrivent le comportement à observer, pas une simple technologie à installer.

8.1 Identification et authentification

ID	Exigence	Critère de validation
SEC-01	Toute opération métier sur une ressource privée exige une session authentifiée et validée par le serveur.	Une requête anonyme reçoit un refus sans exposer la ressource.
SEC-02	Les actions critiques (distribution, révocation, export de rapport) nécessitent une identité valide et des contrôles d'accès actualisés.	Une session expirée ne peut pas exécuter l'action.
SEC-03	Les tentatives répétées de connexion sont limitées et journalisées sans révéler si un compte existe.	Plusieurs essais invalides déclenchent la limitation configurée.
SEC-04	Les jetons et sessions ne sont pas inclus dans les URL, les journaux métier ou les fichiers distribués.	Aucun secret d'authentification dans l'URL ou les logs.

8.2 Autorisation et isolation

ID	Exigence	Critère de validation
SEC-05	Chaque accès à un jeu, une copie ou un rapport vérifie le rôle, l'organisation et la permission sur l'objet.	L'identifiant de la copie d'autrui retourne un refus.
SEC-06	L'administrateur technique n'obtient pas automatiquement l'accès aux données, aux clés ou aux rapports.	Un administrateur sans rôle métier ne peut pas télécharger un original.
SEC-07	Un lien expiré, révoqué ou ayant dépassé son quota n'autorise aucun nouveau téléchargement.	Après expiration/révocation, le téléchargement échoue.
SEC-08	La création et la lecture d'investigations sont réservées aux enquêteurs autorisés dans leur périmètre.	Un utilisateur standard ne peut ni lire ni exporter le rapport.

9 Exigences – données, marques et clés

9.1 Confidentialité et intégrité des données

ID	Exigence	Critère de validation
SEC-09	Le serveur limite taille, nombre de lignes, colonnes et types acceptés ; les fichiers invalides sont rejetés avant traitement.	Fichier hors limites refusé ; aucune donnée publiée.
SEC-10	Les originaux et copies sont conservés en stockage privé ; leur téléchargement passe par l'autorisation serveur.	Une URL directe non autorisée ne retourne pas le fichier.
SEC-11	Les échanges contenant des données, identités ou secrets utilisent un transport chiffré en déploiement.	Les accès protégés en HTTP non chiffré sont refusés ou redirigés de façon sûre.
SEC-12	Toute modification d'une valeur par marquage reste dans la tolérance explicitement définie pour la colonne.	Le rapport calcule et vérifie l'erreur maximale par colonne.
SEC-13	Les colonnes d'identifiants, clés, catégories sensibles et mesures sans tolérance validée ne peuvent pas être tatouées.	La sélection d'une colonne interdite est rejetée côté serveur.
SEC-14	Les hash SHA-256 des originaux et copies sont recalculables pour la vérification exacte de leur intégrité.	Un fichier modifié ne conserve pas la même empreinte exacte.

9.2 Clés et fingerprinting

ID	Exigence	Critère de validation
SEC-15	Les clés maîtres de marquage sont absentes du code, des dépôts Git et des réponses API.	Aucun secret dans l'artefact ou le dépôt d'essai.
SEC-16	Les sous-clés des destinataires sont dérivées avec HKDF à partir d'un secret protégé et d'un contexte distinct.	Deux identités distinctes produisent des sous-clés distinctes ; aucune clé en clair en base.
SEC-17	Les positions de tatouage et les bits attendus dépendent d'un calcul HMAC à clé et d'identifiants stables.	Les résultats sont reproductibles avec la bonne clé, non prévisibles sans elle.
SEC-18	Une distribution n'est validée que si la génération de l'empreinte et le registre sont achevés de façon cohérente.	Échec simulé : aucune copie partiellement valide n'est publiée.
SEC-19	Une empreinte absente, incohérente ou non significative n'est jamais présentée comme attribution certaine.	Résultat « indéterminé » avec justification.

10 Exigences – audit, résilience et investigation

10.1 Intégrité des preuves et audit

ID	Exigence	Critère de validation
SEC-20	Les distributions enregistrent identité autorisée, copie, horodatage, statut et hash ; les registres sont signés.	Une entrée modifiée échoue à la vérification de signature.
SEC-21	Les événements sensibles (import, marquage, téléchargement, révocation, investigation, refus d'accès) sont horodatés.	Événements vérifiables sans contenu confidentiel ni clés.
SEC-22	Le journal est chaîné par hachage et protégé par des permissions limitant sa modification.	Altérer un événement rompt la vérification de chaîne.
SEC-23	Les rapports d'investigation sont signés et incluent version du moteur, seuil, échantillon, résultat et limites.	Un rapport altéré ne passe pas la vérification de signature.

10.2 Décision statistique, disponibilité et reprise

ID	Exigence	Critère de validation
SEC-24	La détection retourne nombre de positions utilisables, concordances, p-valeur et seuil choisi.	Le rapport permet de reproduire la décision.
SEC-25	L'attribution parmi plusieurs sous-clés applique un contrôle des comparaisons multiples et traite les ex-aequo comme inconclusifs.	Une entrée ambiguë ne force aucun destinataire.
SEC-26	La plateforme limite le débit, la durée et les ressources des traitements de marquage et détection.	Une charge dépassant le quota est rejetée ou mise en file de façon contrôlée.
SEC-27	Une panne pendant une distribution ou une investigation n'expose pas un fichier partiellement produit.	Test d'interruption : données et statuts cohérents après reprise.
SEC-28	Les sauvegardes et restaurations documentées incluent données nécessaires et registre de traçabilité.	Un essai de restauration retrouve les données et vérifie leur intégrité.

11 Cas d'abus propres à TupleTrace

11.1 AB-01 – Accès à la copie d'un autre destinataire

Acteur : destinataire authentifié. **But malveillant :** obtenir une autre copie en modifiant une référence. **Actif :** copies et registre. **Protection :** autorisation par objet et par organisation. **Vérification :** toutes les références non autorisées sont refusées (SEC-05, SEC-07).

11.2 AB-02 – Falsification d'un résultat d'investigation

Acteur : utilisateur abusif. **But :** faire apparaître une attribution trompeuse. **Actif :** preuve et réputation des destinataires. **Protection :** signatures, test statistique et statut inconclusif. **Vérification :** modification du rapport détectée ; absence de faux lien forcé (SEC-19, SEC-23 à SEC-25).

11.3 AB-03 – Épuisement du moteur de traitement

Acteur : utilisateur ayant accès à l'importation. **But :** saturer les ressources. **Actif :** disponibilité. **Protection :** limites sur les fichiers, quotas et tâches bornées. **Vérification :** les demandes hors limites sont refusées, les autres restent servies (SEC-09, SEC-26).

11.4 AB-04 – Altération du registre

Acteur : initié disposant d'un accès technique insuffisamment restreint. **But :** modifier le destinataire associé à une copie. **Actif :** intégrité du registre. **Protection :** contrôle des permissions, signatures et journal chaîné. **Vérification :** toute altération de test devient détectable (SEC-20 à SEC-22).

11.5 AB-05 – Retrait ou brouillage des marques

Acteur : destinataire abusif. **But :** rendre la copie difficile à reconnaître par suppression de lignes, arrondi ou bruit. **Protection :** marquage réparti, tests de robustesse et décision prudente. **Vérification :** taux de détection mesuré ; « indéterminé » si preuve insuffisante (SEC-19, SEC-24).

11.6 AB-06 – Comparaison de plusieurs copies

Acteur : plusieurs destinataires. **But :** comparer leurs valeurs pour atténuer le fingerprint individuel. **Protection MVP :** documenter ce risque et ne pas surévaluer la capacité d'attribution. **Extension :** étudier des codes anti-collusion.

12 Plan de vérification et tests de sécurité

12.1 Principe des tests

Les tests sont réalisés sur un environnement maîtrisé, avec des comptes et jeux de données factices. Une exigence *Must* est acceptée lorsqu'un test reproductible démontre le comportement attendu. Les résultats et preuves sont conservés dans le dépôt, sans secrets ni données confidentielles.

Test	Scénario de validation	Exigences	Résultat attendu
T-01	Demander une copie privée sans authentification.	SEC-01	Refus d'accès.
T-02	Accéder à une copie d'une autre organisation.	SEC-05, 06	Ressource inaccessible.
T-03	Réutiliser un lien expiré ou révoqué.	SEC-07	Téléchargement refusé.
T-04	Importer un CSV non valide ou hors quota.	SEC-09, 26	Rejet contrôlé.
T-05	Tenter le marquage d'une colonne interdite.	SEC-12, 13	Opération refusée.
T-06	Modifier une valeur au-delà de sa tolérance.	SEC-12	Copie non publiée.
T-07	Modifier une entrée signée du registre.	SEC-20, 22	Anomalie détectée.
T-08	Modifier un rapport signé.	SEC-23	Signature invalide.
T-09	Soumettre un extrait sans concordance suffisante.	SEC-19, 24	« Indéterminé ».
T-10	Comparer plusieurs destinataires simulés.	SEC-25	Seuil corrigé.
T-11	Interrompre un traitement avant finalisation.	SEC-18, 27	Pas de copie partielle.
T-12	Restaurer une sauvegarde de test.	SEC-28	État vérifié.

12.2 Tests statistiques complémentaires

On mesurera le taux de détection sur données marquées, le taux de faux positifs sur données non marquées et le taux d'identification sur des copies de destinataires simulés. Des attaques contrôlées feront varier les proportions de lignes conservées, l'arrondi, le bruit et les colonnes disponibles. Les conclusions doivent citer le nombre effectif de positions examinées et les paramètres de décision.

13 Justification de la détection statistique

13.1 Principe du test

Pour un extrait suspect, le moteur recalcule les positions qui auraient dû être marquées à l'aide de la clé et des identifiants de lignes. Si n positions utilisables sont observées et k concordent avec les bits attendus, un modèle binomial peut être utilisé sous une hypothèse nulle de bits indépendants et équiprobables :

$$H_0 : K \sim \text{Binomiale}(n, \tfrac{1}{2}), \qquad p = \Pr(K \geq k \mid H_0).$$

Une marque est déclarée détectée uniquement si la p-valeur satisfait le seuil choisi et que les conditions minimales d'analyse sont remplies.

13.2 Comparaisons multiples

Pour N destinataires testés, un seuil corrigé, par exemple

$$\alpha_{\text{ind}} = \frac{\alpha}{N},$$

limite le risque de faux positifs lié aux comparaisons multiples. Le choix final de α est documenté dans les paramètres d'expérience. La valeur 10^{-6} peut servir d'objectif de référence, mais ne constitue pas une garantie empirique de faux positifs sans validation du modèle.

13.3 Conditions de validité et limites

— Le modèle binomial dépend de l'indépendance et de la distribution effective des bits testés.

— Les lignes corrélées, transformations et biais des données doivent être examinés expérimentalement.

— Un faible nombre de lignes compatibles peut rendre la détection non concluante.

— Le système n'assimile pas identification de copie et culpabilité d'une personne.

Le rapport doit distinguer *preuve technique de concordance*, *incertitude statistique* et *hypothèses de calcul*.

14 Gestion des exigences, livrables et évolution

14.1 Suivi et maintenance

Chaque exigence possède un ID, une priorité, un acteur concerné, une menace associée, un test, un statut et une version. Un changement de méthode de watermarking impose la révision des exigences affectées et des tests.

État	**Signification**
Proposée	Exigence rédigée, non encore revue.
Validée	Formulation, priorité et test approuvés par l'équipe.
Implémentée	Contrôle développé, pas nécessairement testé.
Vérifiée	Test réussi et preuve conservée.
À revoir	Exigence impactée par une modification ou un test échoué.

14.2 Définition de « Terminé » pour une exigence

Une fonctionnalité métier est considérée terminée si les autorisations, la validation des entrées, les erreurs, l'audit et les tests de sécurité qui la concernent ont été traités. Aucune fonctionnalité ne doit contourner les protections sous prétexte de simplifier la démonstration.

14.3 Limites et risques résiduels

Les données publiques ou synthétiques réduisent les risques de confidentialité pour la démonstration, mais ne suppriment pas les obligations de sécurisation. La suppression de la majorité des lignes, l'arrondi agressif, la perte des identifiants stables ou la collusion peuvent empêcher la détection. Les rapports doivent annoncer ces limites clairement, sans surpromesse.

14.4 Conclusion

Ce recueil traduit les exigences du cahier des charges en besoins de sécurité traçables et vérifiables. L'approche SQUARE, les cas d'abus et la matrice de tests soutiennent une démarche Shift-Left cohérente avec les trois services métier : watermarking, fingerprinting et investigation statistique.